ISMS-COMPLIANCE-GOVERNANCE

ISMS·ISMS-P·간편인증과 정보 보호 컴플라이언스

연관 기출 · 131-3-6, 138-3-6, 140-4-5, 132-4-6, 129-3-6

한눈에 이해

법과 인증의 요구 사항마다 관련 자산, 위험, 담당자를 정하고 운영 기록을 바탕으로 개선합니다.

정의와 핵심 원리

정보보호 컴플라이언스는 적용 법령·계약·내부 정책·표준의 요구를 식별하고 통제를 구현·검증·개선하는 활동입니다. ISMS는 정보보호 관리체계 인증, ISMS-P는 개인정보 처리 단계 보호까지 포괄하는 통합 관리체계 인증입니다.

• 경영진의 지원을 받아 범위와 조직 정책을 정합니다. 자산과 위험을 식별하고 평가한 뒤 보호 대책을 구현합니다. 운영 점검과 감사에서 찾은 문제를 고치고 다시 평가합니다. 인증 범위 밖의 시스템, 위탁·개발·운영 책임과 예외를 명시합니다. 정책은 목적과 책임을, 절차와 지침은 수행 방법을 정합니다.

• 기술 통제만 아니라 교육·인사·공급자·사고 대응·업무 연속성·개인 권리·물리 보호를 다룹니다. 증거는 접근 권한 승인·회수, 취약점 조치, 백업 복원, 로그 점검, 사고 훈련 등 실제 운영 기록이어야 합니다. 인증서가 사고 0을 보장하지 않습니다.

• ISMS 의무 대상과 간편 인증 적용 기준·항목 수·최신 인증 영역은 법과 고시의 시점별 원문으로 확인해야 합니다. 2023 안내서·2024년 간편 항목 목록을 2026 변경 후 요건과 구분해 확인합니다. 강화 방안은 NHI·클라우드·AI·공급망의 실제 범위 반영, 위험 기반 증빙과 지속 감시라는 제안으로 구분합니다.

구조·비교·판단

구분	핵심 원리	적용·한계
ISMS	정보보호 관리·보호 대책	인증 범위·의무 대상 확인
ISMS-P	개인정보 처리 단계 포함	권리 보호·생애 주기 증빙
준수 운영	법·계약·정책 연결	통제 실행·책임·개선

적용 예제

신규 AI SaaS의 준수 검토

강사 생성 학습 예제입니다. 공식 기준답안이 아닙니다.

조건: 이미 인증을 받은 조직이 외부 AI 서비스를 도입합니다.

1. 도입 범위에 포함된 개인정보·기밀 정보의 흐름, 모델의 입력과 출력, 서비스 계약을 검토합니다.
2. 적용 요구를 통제·소유자·증거·점검 주기에 매핑합니다.
3. 권한·유출·보관·사고 통지·종료 삭제를 시험합니다.
4. 인증 범위 변경과 잔여 위험을 정식 절차로 관리합니다.

결과·해석: 기존 인증을 신규 서비스 전체의 포괄 보증으로 오해하지 않습니다.

전제·주의: 공식 누리집 소개와 자료 목록만 확인했습니다. 2026년 최신 세부 인증 항목·의무 기준·간편 대상 전문은 미열람입니다.

답안 골격과 혼동 방지

준수의 필요성 → 법·정책과 통제의 연결 → 관리 과정 → ISMS·ISMS-P·간편 인증 구분 → 개선안

- 미열람 항목 수를 암기 표로 확정하지 않습니다.
- 인증을 개인정보 유출 면책으로 설명하지 않습니다.

내용을 가리고 회상

1. 정책과 절차의 차이는 무엇입니까?
2. 준수 증거의 실효성을 어떻게 검증합니까?
3. 인증 범위가 중요한 이유는 무엇입니까?

적용 기준과 근거

명시한 출처 판본의 원리를 설명하며 제품별 구현 차이는 별도 확인합니다.

내용 검토 상태: 부분 확인. 출처 확인은 공식 정답이나 학습 성취를 뜻하지 않습니다.

출처별 상세 열람 범위는 위키의 출처 기록에서 확인합니다.

- ISMS-P 공식 누리집 - KISA; 2026 표시 페이지; 확인 2026-11-05.
- 개인정보의 안전성 확보조치 기준 - 국가법령정보센터; 2026-07-01개정표시; 확인 2026-11-05.